

CHALLENGE #19: 3v@I Write-up.

3v@I

Medium

Web Exploitation

picoCTF 2025

browser_webshell_solvable

AUTHOR: THEONESTE BYAGUTANGAZA

Description

ABC Bank's website has a loan calculator to help its clients calculate the amount they pay if they take a loan from the bank. Unfortunately, they are using an `eval` function to calculate the loan. Bypassing this will give you Remote Code Execution (RCE). Can you exploit the bank's calculator and read the flag?
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.
Its current status is:
`NOT_RUNNING`

Launch Instance

Hints ?

1

2

3

Bypass regex

Hints ?

1

2

3

The flag file is `/flag.txt`

Liked

Hints ?

1

2

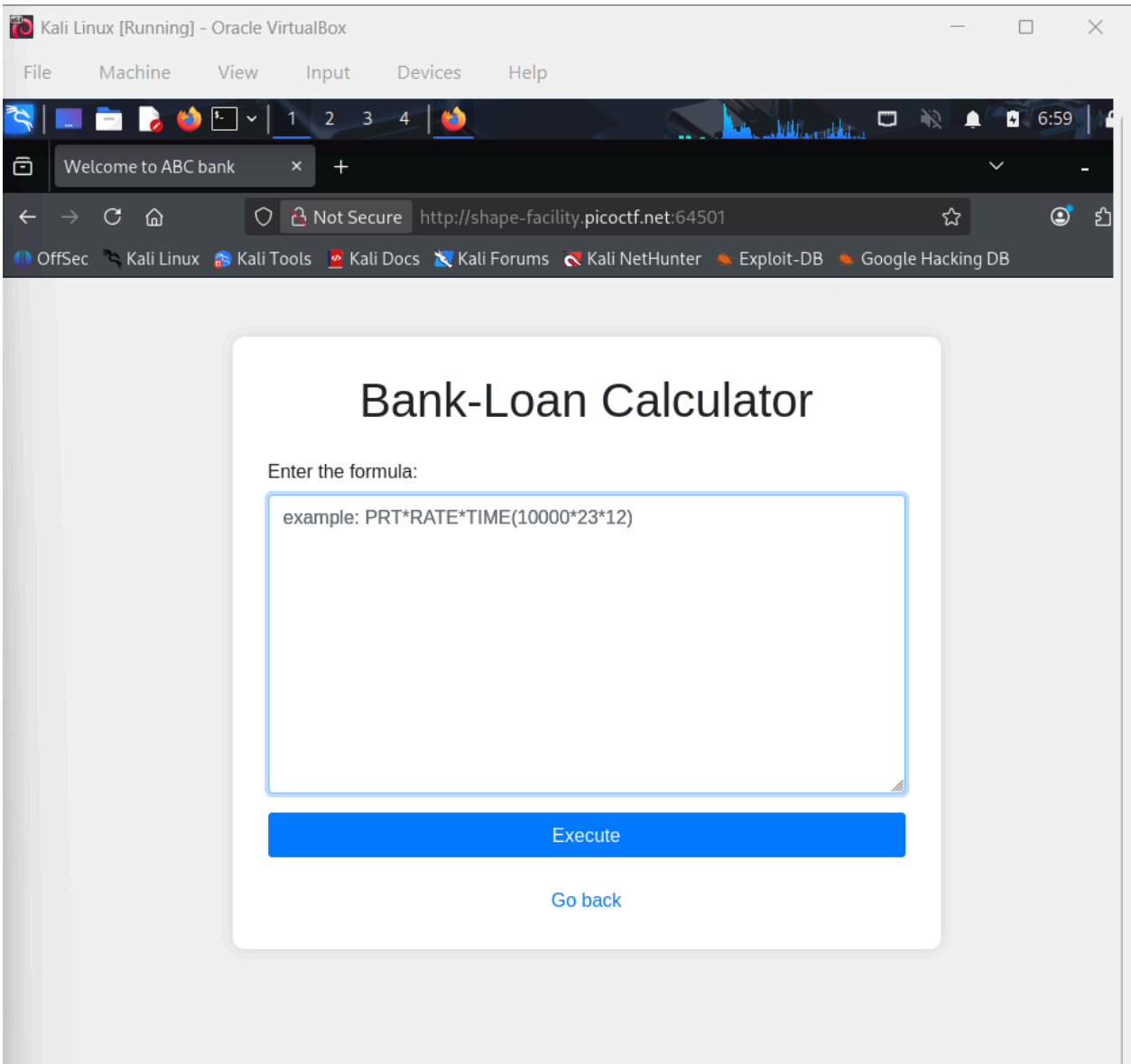
3

You might need encoding or dynamic construction to bypass restrictions.

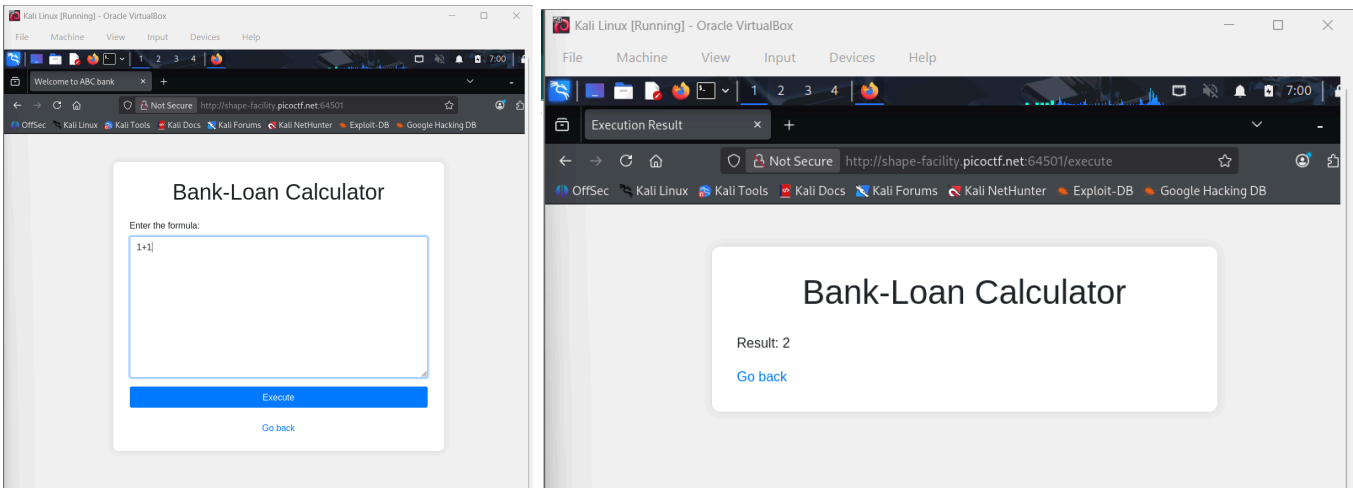
9,564 users solved

picoCTF{FLAG}

Solving Process:



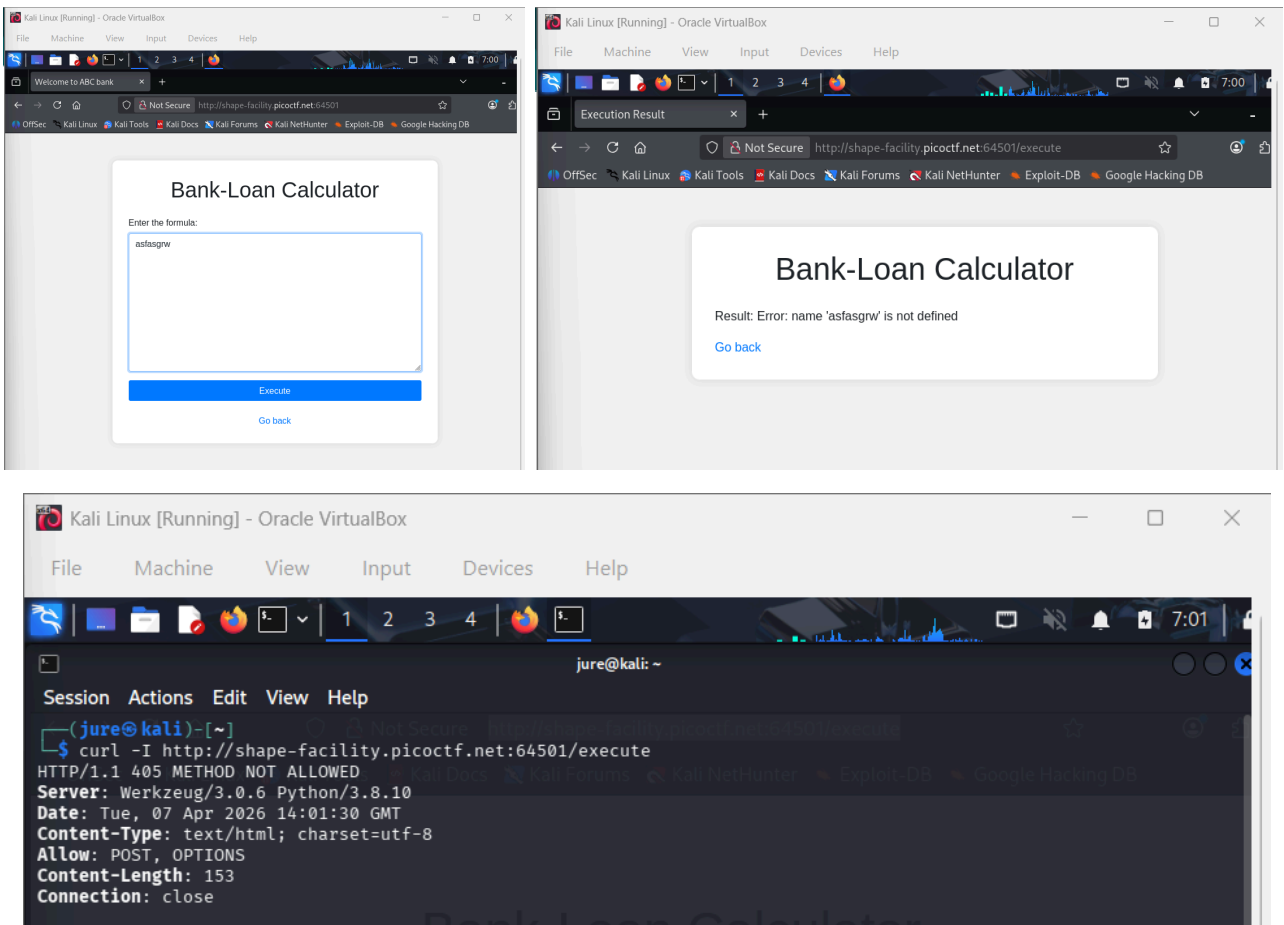
The page appeared to be a **simple bank loan calculator** where users could enter a formula and click Execute to compute the result. For example, entering **1 + 1** returned the result **2**, confirming that the input field evaluated mathematical expressions.



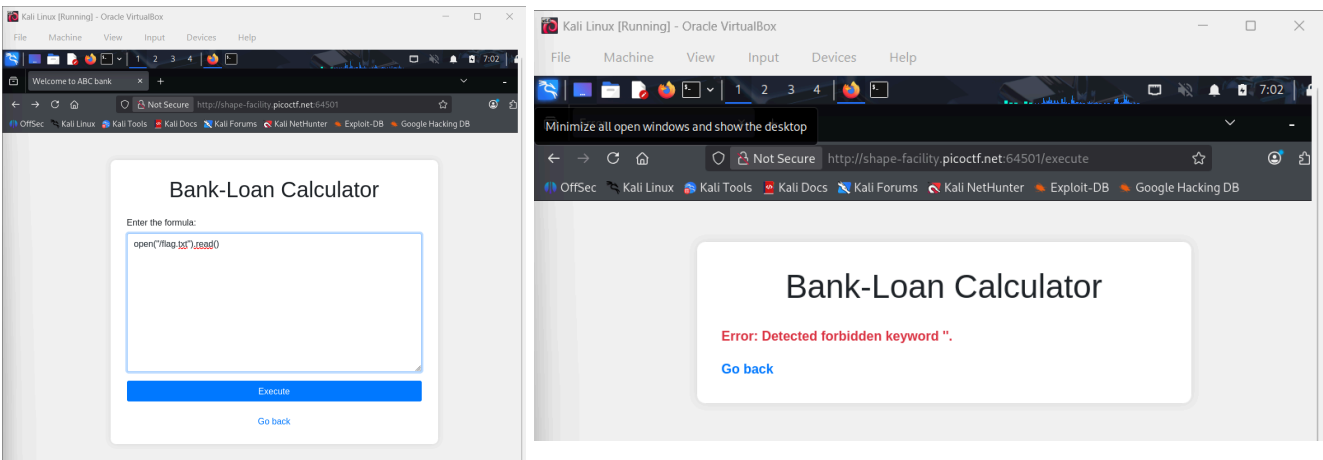
The challenge description indicated that the calculator used an **eval function** to process the input. Since the eval function converts input text into executable code, it can become dangerous

if user input is not properly sanitized. If exploited, it could allow remote code execution on the server.

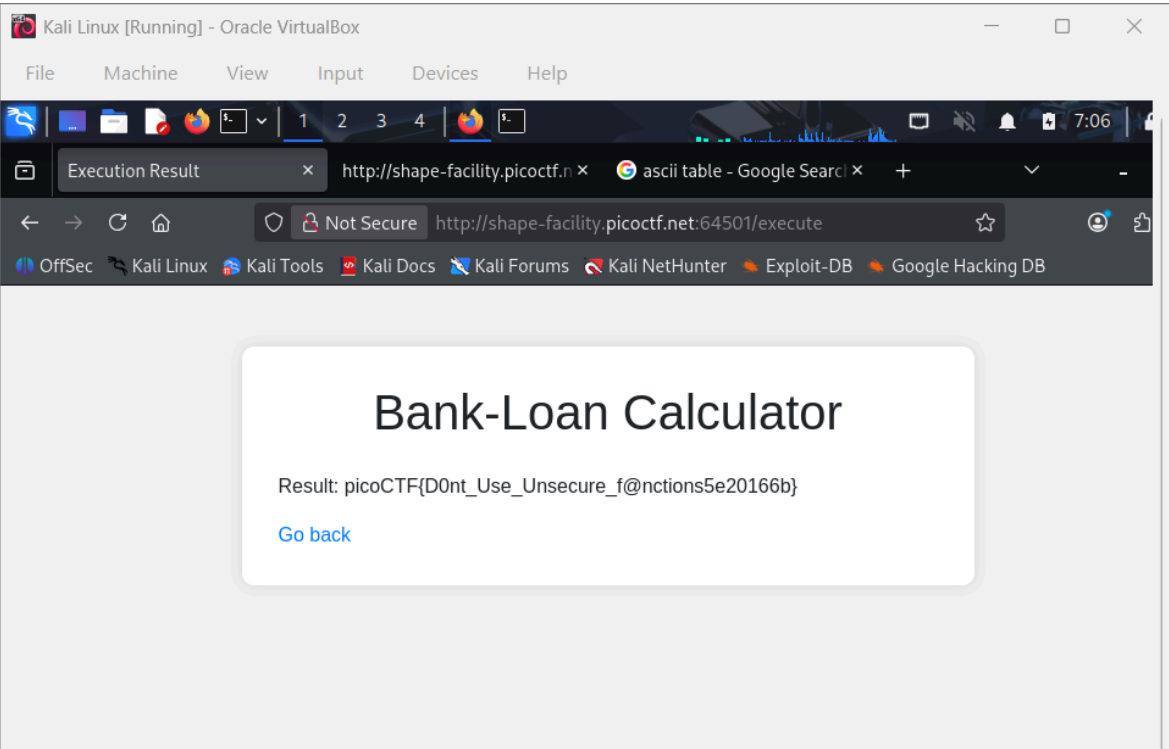
To determine the programming language used by the server, an invalid or random input was entered into the calculator. The resulting error message resembled a Python error, suggesting that the backend was written in Python. This was further confirmed by inspecting the server headers using the command `curl -I <URL>`, which showed that the application was running on a Python web server.



Knowing that Python was used, the next idea was to attempt reading the flag file directly using Python's file-handling functions. A payload using `open("flag.txt").read()` was attempted in the input field to read the contents of the flag file. However, the input was blocked because the application filtered certain forbidden keywords and characters.



After running the payload, the server returned the contents of the flag file, revealing the flag.



3v@l

Medium

Web Exploitation

picoCTF 2025

browser_webshell_solvable

AUTHOR: THEONESTE BYAGUTANGAZA

Description

ABC Bank's website has a loan calculator to help its clients calculate the amount they pay if they take a loan from the bank. Unfortunately, they are using an `eval` function to calculate the loan. Bypassing this will give you Remote Code Execution (RCE). Can you exploit the bank's calculator and read the flag?

The website is running [Here](#).

This challenge launches an instance on demand.

Its current status is: **RUNNING**

Instance Time Remaining: **6:46**

Restart Instance

Hints ?

1

2

3

9,564 users solved

95% Liked

picoCTF{D0nt_Use_Unsecure_f@nctions5e20166b}

Submit Flag

Hurray! You solved this challenge.

Reflection:

This challenge illustrated how unsafe use of the eval function can lead to remote code execution vulnerabilities. Even when filters are implemented, attackers may still bypass them using techniques such as ASCII character reconstruction and string concatenation. The activity highlights the importance of avoiding eval for user input and implementing stronger input validation mechanisms in secure web development.